

Veritas-Medica -- Pre-Demo Prototype Evaluation

Date: 2026-08-03 **Audience:** healthcare specialists, medical advisors, product leadership **Scope:** clinical safety, architecture & LLM readiness, market position, Saudi tailoring, demo readiness.

Builds on [STABILIZATION_AUDIT.md](#), which covers dimensions 1-2 at code level. This document adds what that audit did not: LLM swappability, market benchmarking, Saudi-specific regulatory fit, and demo strategy.

1. Executive Summary

Verdict: a credible, unusually well-disciplined prototype -- demo-ready to clinicians, not yet pilot-ready with real patients.

Maturity by dimension:

Dimension	Rating	One-line verdict
Clinical safety boundaries	Strong	Genuinely differentiated; the discipline is real, not cosmetic
Determinism / anti-hallucination	Strong	Facts come from Cypher, provable by object-equality tests
Architecture & modularity	Good	Clean service split; scaling gaps are known and bounded
LLM swappability	Split	Excellent in apps/qa/apps/narrative ; absent in services/orchestrator
Security & access control	Good	52 RBAC-guarded routes, 53 audit sites, CMEK present
PHI residency	Gap	Guard exists and is bypassed on two paths (H-1)
NPHIES production conformance	Not ready	Profiles unverified; no CCHI certs; coding-standard question open
Market feature parity	Partial	Deep on explainability, thin on EMR integration breadth

What makes this prototype unusual. Most clinical-AI demos are an LLM with a system prompt telling it to be careful. This one separates *reasoning* from *language*: every clinical assertion is a deterministic Neo4j traversal, and the LLM is confined to rewording facts it was handed. That separation is enforced by tests asserting object-equality between what the graph returned and what the UI shows -- not by prompt instructions. That is a genuinely defensible architecture and the single strongest thing to demo.

What would embarrass you in front of a specialist. Three things, all fixable in under a week: agent action cards that do nothing when clicked (M-1), a scribe whose SOAP note is still canned (H-3b), and an ICD coding-standard question (§4.2) that a Saudi coding specialist will spot within minutes.

The honest framing for leadership: this is a strong *architecture* demonstration with a partially-wired *product* surface. Roughly 515 tests pass and the engines are real, but several headline surfaces still read from mock constants. Demo it as "here is how we guarantee correctness," not "here is a working hospital system."

2. Detailed Findings

2.1 Clinical Safety & Workflow -- Strong

Concrete evidence of a real safety posture, not a claimed one:

- **Human-in-the-loop is structural.** The Scribe drafts a Plan update with `applied: False (services/orchestrator/agent_bus.py)` -- the clinician commits it. The receptionist books nothing and sends nothing; every item returns `requires_clinician_review: True`.
- **Suggest -> confirm for all coding.** ICD-10 and SBS codes are *suggested* from reference tables and only persist on explicit clinician confirmation, with free-text codes rejected (`docs/api/08-nphies.md`).
- **The system refuses rather than fabricates.** `submitPreAuth` throws in demo mode rather than simulating an approval; only an explicit payer `complete` outcome turns a badge green -- `queued/partial/unrecognised` all render as *pending* (`services/nphies-engine/fhir_client.py`).
- **Wording boundaries are enforced by test.** Alternative medications are returned as `screened_candidates` with `screen_result: no_contraindication_found`, never "recommended", with a test asserting the word "recommend" never appears.

Residual clinical risks:

- 1 **Scope has drifted past the original CLAUDE.md boundary -- knowingly.** DDI checking, renal dose alerting, differential-diagnosis prose and dose phrasing were all explicitly forbidden by the original governing document as SaMD-boundary-crossing, and were each built after being flagged and confirmed. This is documented in module docstrings, but **it has not been through the CTO + Clinical Advisor + Regulatory Consultant sign-off the project's own process requires.** That sign-off is the gating item before any real-patient use, and it is the single most important thing to put in front of your medical advisors.
- 1 **Alternative screening has no therapeutic-class filter.** Screening a flagged Metformin returns Warfarin and NSAIDs -- individually safe for that patient, pharmacologically unrelated. The graph holds no ATC data. The payload now carries explicit `limitations`, but a clinician seeing that list unlabelled would lose confidence instantly. **Do not demo this feature without reading the limitations aloud.**
- 1 **Speaker attribution in dictation is assumed.** Transcribed lines are labelled "clinician" because that is who pressed record, not because the audio was diarised. Acceptable now; not acceptable in a shared consultation room.

2.2 PHI, Privacy & Compliance -- Gap (known, deferred)

`packages/phi-guard` is a genuinely well-designed control: fail-closed residency classification, three policies (`block/deidentify/allow`), and an `allow` mode that requires a verbatim acknowledgement string so it cannot be enabled by a stray env var.

It is bypassed on two paths. `services/orchestrator/deepseek_client.py` has zero `phi_guard` references and does not list it as a dependency; `apps/narrative` likewise, while configured with `NARRATIVE_MODEL_PROVIDER=deepseek`. `apps/qa` and `services/nphies-engine` *do* honour it -- so this is an inconsistency, not a design decision.

What crosses: full encounter transcripts (`generate_soap_note`) and NSCRE graph facts including patient IDs, medication names and eGFR values (`format_agent_prose`) -- to `api.deepseek.com`, which classifies as EXTERNAL.

Deferred by explicit decision on the basis that the prototype runs on synthetic data. That reasoning is sound *only while the data is synthetic*, and this becomes a hard blocker the moment a real record enters the system.

Other compliance observations:

- Audit logging is broad -- 53 write sites, append-only with hash-chain integrity and a verify endpoint. Metadata discipline is good: counts, not clinical content.
- Encryption at rest exists via customer-managed keys
(`apps/core/src/security/`).

- **Gap:** no documented data-retention or right-to-erasure flow for the Neo4j

graph. A DSR module exists for Postgres; the PSKG is a second copy of patient facts with no equivalent. Under PDPL that is a real exposure.

2.3 Architecture & Modularity -- Good

Clean separation: `apps/core` (NestJS) is the single authenticated gateway; every Python service sits behind it and is never browser-reachable. That discipline held across all ten sprints and is worth calling out.

Scaling limitations, all bounded and known:

Limitation	Location	Impact
In-process task queue	<code>services/nphies-engine/tasks.py</code>	Tasks don't survive restart or distribute across replicas
In-process SSE broker	same	Multi-replica deployment would drop events for clients on other pods
In-process agent bus	<code>services/orchestrator/agent_bus.py</code>	Same; no durable replay
Free-text medication merge key	<code>etl_pskg.py</code>	"warfarin 3mg" and "warfarin" are distinct nodes

All four are documented in-code with the migration path named (Celery / Redis / Postgres outbox). The medication-key brittleness is the one with clinical consequence: a dose-suffixed name silently misses its own contraindication edges.

2.4 LLM Flexibility -- Split, and this is the key technical finding

`apps/qa` and `apps/narrative` are well-abstracted -- better than typical.

`apps/qa/src/qa/model_client.py` defines a `ModelProvider` Protocol (`complete()` + `version()`), with `StubModelProvider` and `LocalModelProvider`. Critically, `LocalModelProvider` speaks an **OpenAI-compatible** `/chat/completions` endpoint. That means swapping to vLLM, Ollama, llama.cpp, Azure OpenAI, Together or a self-hosted Llama 3 is a **configuration change, not a code change**:

```
QA_MODEL_PROVIDER=local
MODEL_ENDPOINT_URL=https://llm.hospital.sa/v1
MODEL_NAME=llama-3.3-70b-instruct
PHI_INKINGDOM_HOSTS=llm.hospital.sa
```

The PHI guard is wired into this provider, so an in-Kingdom endpoint becomes a pass-through automatically. This is a genuinely strong answer to "can you run this on our own hardware?" -- **yes, for QA and narrative, today**.

`services/orchestrator/deepseek_client.py` has none of this. No Protocol, no provider switch, no guard, `DEFAULT_BASE_URL = "https://api.deepseek.com"` and `DEFAULT_MODEL = "deepseek-chat"` hardcoded. Everything built in Sprints 8-10 -- all five agents, the handoff chain, the receptionist -- routes through it.

Consequence: the newest and most demo-visible half of the product is the half that cannot be moved off DeepSeek without code changes. Retrofitting it to the existing `ModelProvider` pattern is perhaps a day's work and would resolve both this and the H-1 PHI gap in one change. **This is my highest-value technical recommendation.**

Prompt & context management: 12 prompt templates are documented in `docs/prompts/` with versioning and a stated change-control process, but 44 system prompts live inline in Python. The docs describe the prompts rather than being their source of truth -- a drift risk. No token budgeting or context-length management exists anywhere; transcripts are sent whole. Fine at demo scale, a real cost and truncation risk at ward scale.

2.5 Security & Access Control -- Good

- OIDC via Keycloak; session-cookie auth.
- 52 routes behind `@RequirePermission`, plus patient-scope checks that fail-closed (verified: an out-of-scope patient returns `PATIENT_OUT_OF_SCOPE`).
- Scope derives from `hospital.encounter.attending_user_id` with a TTL cache -- a defensible model, though it means scope is encounter-driven and a consulting specialist not listed as attending sees nothing.
- CMEK encryption service present with a local key provider for dev.
- **Gap:** API keys live in `.env` (correctly gitignored, verified untracked).

No secrets-manager integration. Acceptable for prototype; needs Vault/KMS/Secrets Manager before pilot.

3. Market & Saudi Tailoring

3.1 Competitive Position

Where this beats the market: the evidence chain. Abridge, Nuance DAX and Suki all produce notes; none of them show you the *graph traversal* that justifies a claim. "Click any assertion, see the exact query path" is a differentiator that specialists will immediately understand, and it is architecturally real here rather than a UI veneer.

Where the market beats this:

Capability	Market standard	Here
EMR integration breadth	Epic/Cerner certified apps, SMART-on-FHIR launch	FHIR R4 client + HL7 v2 adapter; no SMART launch, no certified app
Note formats	Multi-specialty templates, billing-ready	SOAP + specialty templates; narrower
Ambient maturity	Diarisation, multi-speaker, ambient-in-room hardware	Single-stream, no diarisation
Deployment	SOC2 / HITRUST attested	None yet
Scale evidence	Multi-site production references	Prototype, synthetic data only

Realistic positioning: not a Nuance DAX competitor today. It is a credible "NPHIES-native clinical documentation and claim-integrity layer for Saudi providers" -- a narrower, more defensible claim where the local integration and explainability actually matter.

3.2 Saudi Tailoring -- the highest-value section

Regulatory (verified against current sources):

- SDAIA is the PDPL regulator; NDMO sets national data-governance policy; NCA owns cybersecurity controls; CST's Cloud Computing regulations govern hosting. **Health data is PDPL-sensitive**, and sensitive-tier processing requires explicit consent, enhanced controls, DPO oversight, and -- for cross-border transfer -- **SDAIA authorisation plus a mandatory risk assessment**.

- **Direct implication for H-1:** sending clinical transcripts to

`api.deepseek.com` is a cross-border transfer of sensitive health data. On synthetic data that is a non-issue. On real data it requires SDAIA authorisation you will not get for a China-hosted general-purpose LLM. **The self-hosted path is not a nice-to-have for KSA -- it is the only viable production path**, which makes \$2.4's abstraction gap a commercial blocker, not just a technical one.

- Architecture supports in-Kingdom hosting well: everything is containerised,

the PHI guard has an explicit in-Kingdom allowlist, and `docs/architecture/` already documents an on-prem model path. AWS KSA (Riyadh), Oracle Riyadh or on-prem are all reachable without redesign.

NPHIES integration -- one open question that matters:

Current NPHIES guidance describes **HL7 FHIR R4 with Saudi-specific profiles, conformance testing of all profiles before production, digital signatures using CCHI certificates renewed annually**, and a code set spanning **ICD-10-CM, LOINC, SFDA drug codes and CPT plus Saudi procedure codes**.

This codebase uses ICD-10-AM throughout -- `icd10am_code`, `app.snomed_icd10am_map`, and the FHIR system URI `http://hl7.org/fhir/sid/icd-10-am`. Saudi Arabia has historically used ICD-10-AM via the Australian consortium for CCHI/SBS, and current public sources also reference ICD-10-CM. **I could not resolve which variant your NPHIES submissions actually require, and I am not going to guess** -- the two are not interchangeable and a wrong system URI is a rejection cause.

This is the single best question to put to your coding specialists at the demo. If the answer is CM, it is a mechanical but wide change: the mapping table, the coding service, the FHIR system URI, and the seeded reference data.

Also still open: `profiles_verified: false` on the NPHIES engine -- the canonical profile URLs are structurally plausible placeholders, correctly flagged at runtime, awaiting the real IG from CCHI onboarding. And no CCHI certificate / digital-signature handling exists yet.

Language & culture:

- Arabic is present throughout -- RTL support, `ar.json` i18n, an Interpreter

mode, and a documented rule that clinical terms, values and units are preserved **verbatim** rather than translated (`docs/prompts/`). That rule is correct and unusual; keep it.

- Transcription runs faster-whisper large-v3, which handles MSA reasonably and

Gulf dialect poorly -- a limitation you have already observed in testing. Realistic mitigations: a Saudi-dialect fine-tune, or a medical-term glossary pass (already built: `extract_terms.py`) to catch what the ASR garbles.

- Not yet handled: Hijri date display, Arabic patient-facing message templates,

and gender-of-clinician preferences in scheduling -- all low-effort, all noticed immediately by Saudi clinicians.

4. Roadmap

Priority 1 -- Must-fix before the demo (?3-5 days)

- 1 **Wire or disable the agent action cards (M-1).** Eight buttons across five

tabs currently append a chat line and nothing else. A specialist *will* click "Adjust Dosage". Either wire them or mark them "Pending integration" as `ReceptionistTab` now does. **Highest credibility risk.**

- 1 **Wire SOAP generation to `generate_soap_note()` (H-3b).** Dictation is now

real; the note it produces is still a six-stage canned reveal. The gap between "I spoke and it transcribed" and "the note is pre-written" is exactly where a clinician loses trust.

- 1 **Resolve the ICD-10-AM vs ICD-10-CM question** -- or explicitly put it on the agenda as a question rather than being caught by it.
- 1 **Prepare the alternative-screening caveat script.** If you demo it, read the limitations. If you can't, skip it.
- 1 **Add a just restart-services target (L-1).** Stale processes serving old code has produced phantom failures twice; do not let it happen live.

Priority 2 -- Post-demo prototype hardening (2-4 weeks)

- 1 **Retrofit `deepseek_client.py` to the `ModelProvider` pattern.** Resolves LLM lock-in *and* H-1 in one change. Demonstrate a self-hosted Llama 3 swap -- for a Saudi buyer this is the most commercially important demonstration you can make.
- 1 **Move the 44 inline system prompts behind the documented templates** so `docs/prompts/` is the source of truth, not a description.
- 1 **Persist checklist state (M-7)** and finish the remaining wiring gaps.
- 2 **Add ATC/therapeutic-class data** to the graph so alternative screening can filter by class.
- 1 **Obtain the CTO + Clinical Advisor + Regulatory Consultant sign-off** the project's own process requires for the DDI / dose-safety / differential capabilities already built.

Priority 3 -- Production architecture (before any real-patient pilot)

- 1 **Durable queues and shared event bus** -- Celery/Redis or a Postgres outbox, replacing the three in-process brokers.
- 1 **CCHI onboarding:** real IG profiles, conformance testing, certificate lifecycle with annual renewal.
- 1 **Secrets manager** replacing `.env`.
- 2 **PDPL data lifecycle for Neo4j** -- retention and erasure parity with the Postgres DSR module.
- 1 **In-Kingdom hosting** with a self-hosted model endpoint; SDAIA/NDMO data classification exercise.
- 1 **Speaker diarisation** and Saudi-dialect ASR improvement.
- 2 **SOC2 / HITRUST** track if targeting private hospital groups.

5. Demo Strategy

Lead with the evidence chain. It is the strongest, most complete, most differentiated thing you have, and it is now visible in demo mode.

Sequence: evidence chain -> NPHIES badge + 1-click pre-auth -> NSCRE safety check (terminal cutaway, real captured data) -> AI Team handoffs. Keep the ambient scribe */ate* or skip it until P1 #2 lands.

Say the quiet part first. Open by naming what is mocked. Specialists trust a team that volunteers its gaps far more than one they catch out.

Questions that will produce the most actionable feedback

Clinical:

- 1 Where exactly should the line sit between "the graph found a contraindication" and "the system suggested an alternative"? Is *screened candidates* a useful artefact, or does anything short of a recommendation just add noise?
- 1 Is encounter-scoped access (attending clinician only) right, or do consulting specialists need a break-glass path?
- 1 What would you need to see before signing off DDI and renal-dose alerting for real patients?

Coding / RCM:

- 1 ICD-10-AM or ICD-10-CM for NPHIES submission?
- 2 Does the suggest->confirm pattern match how your coders actually work, or does it add clicks to a job they already do fast?
- 1 Which rejection reasons cost you most? Are we validating the right things?

Workflow:

- 1 At what point in a consultation would you actually look at the right-hand drawer -- or would you never?
- 1 Is a scrolling master timeline the right centre-pane default, or should orders lead?

Leadership:

- 1 Is "NPHIES-native documentation + claim integrity" the right wedge, or should this position as an ambient-scribe competitor?
- 1 Does in-Kingdom self-hosted deployment change the buying conversation enough to justify prioritising it?

Sources

- [Saudi Arabia transforms healthcare with NPHIES data exchange | CIO](#)
- [NPHIES -- Council of Health Insurance](#)
- [NPHIES Integration \(KSA\) | Bonami Software](#)
- [Software Regulatory Compliance Requirements Saudi Arabia by Industry \(2026\)](#)
- [SDAIA and Saudi PDPL: What Saudi Organizations Must Know in 2026](#)
- [Saudi PDPL compliance operating map](#)
- [Data localization and regulation of non-personal data -- Saudi Arabia | Baker McKenzie](#)
- [Data Protection & Privacy 2026 -- Saudi Arabia | Chambers and Partners](#)